

IRCTC-Booking-Platform-Threat-Model

Owner: Vanshikha Panwar

Reviewer:

Contributors:

report.releasedAt: Sat Aug 29 2026



OWASP Threat Dragon

Executive Summary

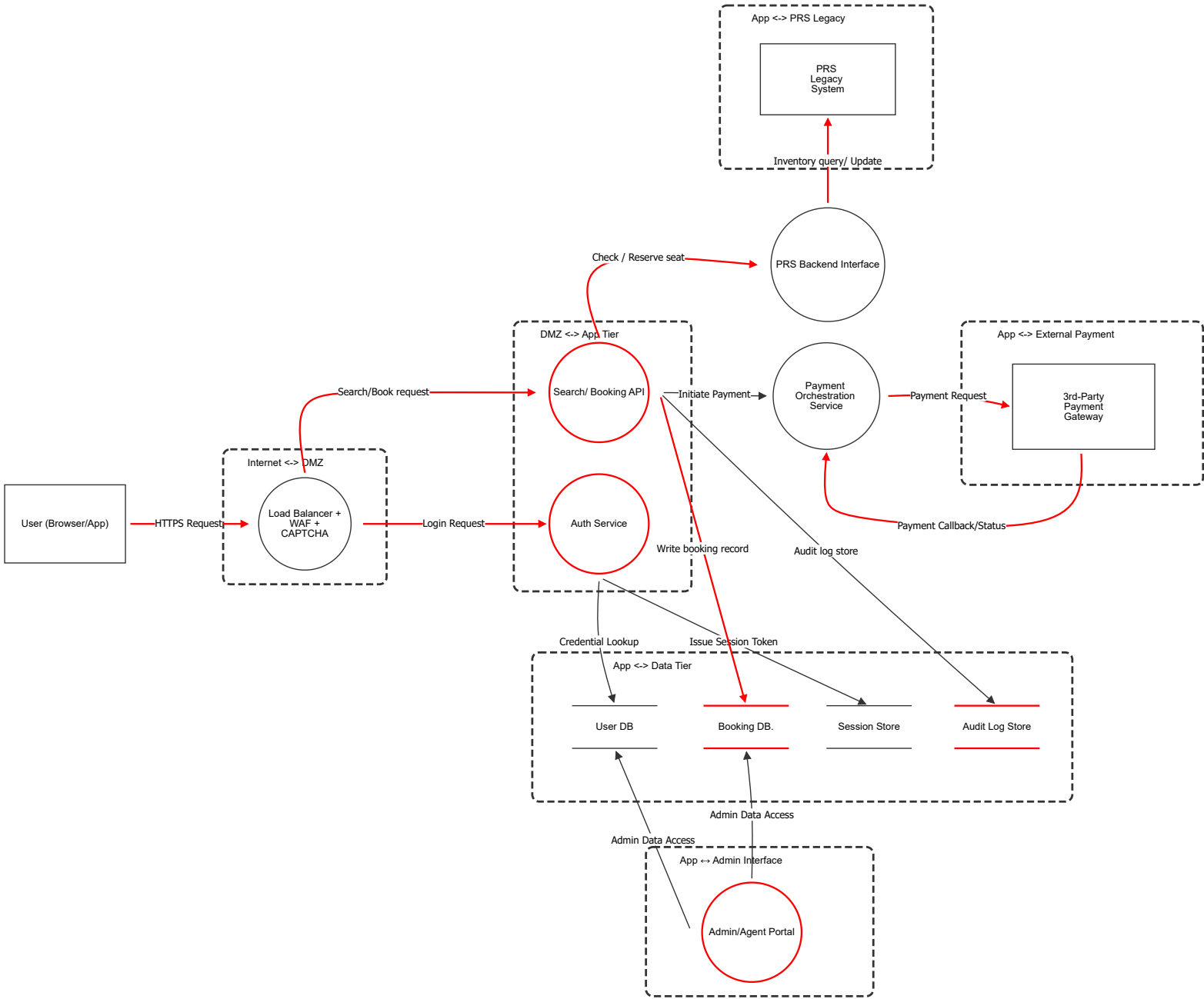
High level system description

Not provided

Summary

Total Threats	14
Total Mitigated	0
Total Open	14
Open / Critical Severity	0
Open / High Severity	8
Open / Medium Severity	5
Open / Low Severity	1

New STRIDE diagram



New STRIDE diagram

Auth Service (Process)

Description: Handles login, session issuance

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	T1 - Credential Stuffing / Account Takeover	Spoofing	High	Open		No MFA, weak lockout policy. Attacker uses leaked password lists against login endpoint to achieve account takeover.	MFA, breach-password blocklist check, progressive lockout with exponential backoff
8	T8 - Session Fixation/Hijack	Spoofing	Medium	Open		Session token not rotated post-login and/or not device-bound; attacker fixes or steals token to inherit victim privilege.	Token rotation on privilege change, short TTL, device/IP binding

Search/ Booking API (Process)

Description: Core booking logic

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	T3 - CAPTCHA Bypass / Scalping	Elevation of privilege	High	Open		Headless browser automation or CAPTCHA-solving services bypass anti-bot controls to gain unfair inventory access during high-contention booking windows.	Behavioral bot-detection (mouse movement/timing entropy) in addition to static CAPTCHA

Booking DB. (Store)

Description: PNR, ticket records

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	T4 - IDOR on Booking/Profile Data	Information disclosure	High	Open		Server-side authorization missing on object reference (PNR/booking ID). Attacker increments ID parameter to view another user's booking/PII. Note: root exposure point is a missing "view booking" read flow not currently modeled — see diagram gap note.	Server-side authorization check on every object reference; never trust client-supplied ID ownership

Audit Log Store (Store)

Description: Immutable transaction logs

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	T7 - Repudiation via Weak Audit Trail	Repudiation	Medium	Open		No immutable audit logging; user can dispute a booking/payment with no verifiable trail.	Immutable, centrally-shipped audit logs with cryptographic hashing (append-only)

Login Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
18	T9 - Information Disclosure via Verbose Errors	Information disclosure	Low	Open		Distinct error messages ("invalid password" vs "invalid user") or stack traces enable username enumeration and backend fingerprinting.	Generic error responses; strip stack traces in production

Write booking record (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	T4 - IDOR on Booking/Profile Data	Information disclosure	High	Open		Server-side authorization missing on object reference (PNR/booking ID). Attacker increments ID parameter to view another user's booking/PII. Note: root exposure point is a missing "view booking" read flow not currently modeled — see diagram gap note.	Server-side authorization check on every object reference; never trust client-supplied ID ownership

Payment Callback/Status (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
17	T6 - Payment Status Tampering	Tampering	High	Open		Client-side or weakly-signed payment callback trusted without server-to-server verification; attacker forges "payment success" response.	Server-to-server payment status verification only; never trust client callback

HTTPS Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	T2 - Tatkal Window DoS via Bot Flooding	Denial of service	High	Open		Automated bots fire booking requests at millisecond precision when Tatkal window opens, exhausting available capacity/inventory for legitimate users.	Adaptive rate-limiting keyed on device fingerprint, not just IP; behavioral bot detection

Search/Book request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	T2 - Tatkal Window DoS via Bot Flooding	Denial of service	High	Open		Automated bots fire booking requests at millisecond precision when Tatkal window opens, exhausting available capacity/inventory for legitimate users.	Adaptive rate-limiting keyed on device fingerprint, not just IP; behavioral bot detection

Check / Reserve seat (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
14	T5 - Seat Inventory Race Condition (read side)	Tampering	Medium	Open		Stale "seat available" read precedes write commit; concurrent requests both pass validation (TOCTOU).	Optimistic/pessimistic locking, idempotency keys on booking writes

Inventory query/ Update (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
15	T5 - Seat Inventory Race Condition (read side)	Tampering	Medium	Open		Stale "seat available" read precedes write commit; concurrent requests both pass validation (TOCTOU).	Optimistic/pessimistic locking, idempotency keys on booking writes

Payment Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
16	T6 - Payment Status Tampering	Tampering	High	Open		Client-side or weakly-signed payment callback trusted without server-to-server verification; attacker forges "payment success" response.	Server-to-server payment status verification only; never trust client callback

Admin/Agent Portal (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	T10 - Admin/Agent RBAC Gap	Elevation of privilege	Medium	Open		Insufficient separation between customer-facing and admin/back-office interfaces; shared auth infrastructure risks privilege bleed.	Strict RBAC/ABAC; separate network segments for back-office; independent auth for admin portal